



CIFP César Manrique.

Ciberseguridad en Entornos de las Tencologías de la Información.

Módulo: Incidentes de Ciberseguridad (IHC)

Profesor: Luis Martínez Ibáñez

Informe de Auditoría de Seguridad en Metasploitable 2 con Lynis

Juan Carlos Francisco Mesa

Octubre, 2025



Esta obra está licenciada bajo la Licencia Creative Commons Atribución 4.0 Internacional. Para ver una copia de esta licencia, visite <http://creativecommons.org/licenses/by/4.0/> o envíe una carta a Creative Commons, PO Box 1866, Mountain View, CA 94042, USA.

Índice

Introducción.....	1
Resultados por Investigación.....	2
Investigación 1: Versión del Kernel.....	2
1. ¿Qué versión del kernel tiene Metasploitable 2?.....	2
2. ¿Cuántos AÑOS tiene este kernel desactualizado?.....	2
3. ¿Qué código de warning de Lynis hace referencia a esto? (KRNL- XXXX).....	2
4. ¿Por qué es peligroso usar un kernel tan antiguo?.....	2
5. ¿Qué tipo de vulnerabilidades podría tener un kernel de 17 años?.....	2
Investigación 2: Seguridad de Usuarios.....	4
Salida del comando cat /etc/shadow grep '::::'.....	4
1. ¿Qué código de warning de Lynis detecta usuarios sin contraseña? (AUTH-XXXX).....	5
2. ¿Cuántos usuarios con shell interactiva existen en el sistema?.....	5
3. ¿Hay algún usuario sin contraseña? ¿Cuál?.....	5
4. ¿Por qué es crítico que un usuario no tenga contraseña?.....	5
5. ¿Qué podría hacer un atacante con esta vulnerabilidad?.....	5
Investigación 3: Seguridad SSH.....	7
1. ¿Qué códigos de warning SSH detecta Lynis? (SSH-XXXX).....	7
2. ¿Está permitido el login de root por SSH? (PermitRootLogin).....	7
3. ¿Acepta autenticación por contraseña? (PasswordAuthentication).....	7
4. ¿Qué versión de OpenSSH está instalada?.....	7
5. ¿Por qué es peligroso permitir root login por SSH?.....	7

6. ¿Qué método de autenticación es más seguro: password o keys?.....	7
Investigación 4: Estado del Firewall.....	8
1. ¿Qué código de warning detecta Lynis sobre el firewall? (FIRE-XXXX).....	8
2. ¿Hay reglas de firewall configuradas en iptables?.....	8
3. ¿Está ufw (Uncomplicated Firewall) activo?.....	8
4. ¿Cuál es la política por defecto? (ACCEPT/DROP).....	8
5. ¿Qué riesgos implica no tener firewall?.....	8
6. ¿Qué servicios quedan expuestos sin protección?.....	9
Investigación 5: Gestión de Actualizaciones.....	10
1. ¿Qué códigos de warning sobre paquetes detecta Lynis? (PKGS-XXXX).....	10
2. ¿Qué versión de Ubuntu está instalada?.....	10
3. ¿Cuándo fue la última actualización del sistema?.....	10
4. ¿Cuántos años hace que terminó el soporte de esta versión?.....	10
5. ¿Qué implica usar un SO sin soporte oficial?.....	10
6. ¿Podrías actualizar este sistema a una versión moderna? ¿Por qué?.....	11
Investigación 6: Controles de Acceso Obligatorio (MAC).....	12
1. ¿Qué código de warning detecta Lynis sobre MAC? (MACF-XXXX).....	12
2. ¿Está SELinux instalado y activo?.....	13
3. ¿Está AppArmor instalado y con perfiles cargados?.....	13
4. ¿Qué sistema MAC (si alguno) está protegiendo el sistema?.....	13
5. ¿Qué es un sistema MAC y para qué sirve?.....	13
6. ¿Qué riesgos existen sin protección MAC?.....	13
Investigación 7: Permisos de Archivos Críticos.....	14

1. ¿Qué códigos de warning sobre permisos detecta Lynis? (FILE-XXXX).....	14
2. ¿Qué permisos tiene el archivo /etc/shadow?.....	14
3. ¿Son correctos esos permisos o permiten lectura no autorizada?.....	14
4. ¿Cuántos binarios con bit SUID encuentra el comando find?.....	14
5. ¿Qué es el bit SUID y por qué puede ser peligroso?.....	14
6. ¿Qué información sensible hay en /etc/shadow?.....	15
Investigación 8: Servicios en Ejecución.....	16
1. ¿Qué códigos de warning sobre servicios detecta Lynis? (BOOT-XXXX).....	16
2. ¿Cuántos procesos hay ejecutándose en el sistema?.....	16
3. ¿Cuántos puertos están en estado LISTEN?.....	16
4. ¿Crees que todos estos servicios son necesarios? ¿Por qué?.....	16
5. ¿Qué principio de seguridad se viola al tener tantos servicios activos?.....	17
6. Nombra 3 servicios que detectes que NO sean esenciales para un servidor.....	17
Tabla Resumen de Hallazgos.....	18
Preguntas de Análisis Crítico Final.....	19
Priorización: ¿Qué 3 vulnerabilidades corregirías primero? ¿Por qué?.....	19
Vectores de ataque: Describe un escenario realista donde un atacante combine varias vulnerabilidades.....	20
Hardening: Ordena tus recomendaciones de endurecimiento y justifica el orden.....	21
Compensación: Si no puedes actualizar el kernel, ¿qué controles alternativos usarías?.....	22
Detección vs Prevención: ¿Qué hallazgos son detectables por un IDS/IPS? ¿Cuáles solo se previenen con configuración?.....	23

Contexto real: Si esto fuera un servidor en producción, ¿cuál sería tu plan de acción inmediato?

..... 24

Conclusiones.....25

Anexos.....26

Índice de imágenes

Imagen 1: Salida del comando <code>cat /etc/shadow grep '::'</code>	4
Imagen 2: Usuarios con shell interactiva (<code>/bin/bash</code> o <code>/bin/sh</code>).....	5
Imagen 3: Salida de <code>iptables -L -n</code> y <code>ufw status</code>	8
Imagen 4: Versión de Ubuntu y Fecha de última actualización.....	10
Imagen 5: Resultado de <code>sestatus</code>	12
Imagen 6: Resultado de <code>apparmor_status</code>	12
Imagen 7: Permisos de <code>/etc/shadow</code> , <code>/etc/passwd</code> , <code>/etc/group</code> y lista de binarios SUID (<code>find /usr/bin -perm -4000</code>).....	14
Imagen 8: Número de procesos y de puertos en escucha.....	16
Imagen 9: Encabezado del reporte obtenido por pantalla.....	26
Imagen 10: Resultados del módulo del Kernel.....	26
Imagen 11: Módulo de usuarios, grupos y autenticación.....	27
Imagen 12: Módulo de firewall.....	27
Imagen 13: Módulo de servidor web.....	28
Imagen 14: Warnings.....	29
Imagen 15: Sugerencias.....	29
Imagen 16: Detalles del análisis.....	30

Introducción

Breve contexto: propósito de la actividad (AE1.2 – Fase 1)

Objetivo general: identificar 8–12 vulnerabilidades de configuración/SO en Metasploitable 2

Metodología: uso de Lynis + comandos del sistema, análisis guiado por pistas

Entorno de laboratorio: Kali (auditor) → Metasploitable 2 (objetivo) vía SSH

Herramienta principal: Lynis (preinstalado en Metasploitable 2)

Resultados por Investigación

(Cada sección debe incluir: hallazgos reales, respuestas a las preguntas específicas y análisis técnico)

Investigación 1: Versión del Kernel

1. ¿Qué versión del kernel tiene Metasploitable 2?

2.6.24-16-server

2. ¿Cuántos AÑOS tiene este kernel desactualizado?

El kernel 2.6.24 se lanzó en enero de 2008. Hoy es 2025, por lo tanto tiene 17 años.

3. ¿Qué código de warning de Lynis hace referencia a esto? (KRNL-XXXX)

En esta auditoría, no se generó un warning específico sobre la antigüedad del kernel, pero Lynis reportó KRNL-6000: "One or more sysctl values differ from the scan profile and could be tweaked", lo cual es un indicador indirecto de que el kernel carece de controles de seguridad modernos. Además, el sistema opera con un kernel que no recibe parches de seguridad desde hace más de una década.

4. ¿Por qué es peligroso usar un kernel tan antiguo?

Un kernel de 2008 no incluye correcciones para cientos de vulnerabilidades descubiertas desde entonces, como:

- CVE-2009-1895 (escalada de privilegios)
- CVE-2010-3880 (inversión de privilegios)
- Dirty COW (CVE-2016-5195) — aunque posterior, sistemas antiguos no tienen mitigaciones.

Además, carece de mecanismos modernos como KASLR, SMEP, SMAP, y protecciones contra ataques de side-channel.

5. ¿Qué tipo de vulnerabilidades podría tener un kernel de 17 años?

Principalmente:

- Escalada de privilegios local (LPE): un atacante con acceso limitado puede obtener root.
- Denegación de servicio (DoS) mediante exploits de memoria.

-
- Fugas de información del kernel.
 - Ausencia de ASLR/DEP en muchos subsistemas.
 - Vulnerabilidades en drivers obsoletos (ej. USB, red).

[Volver al índice](#)

Investigación 2: Seguridad de Usuarios

Salida del comando `cat /etc/shadow | grep '::'`

```
msfadmin@metasploitable:~$ sudo cat /etc/shadow | grep '::'
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync*:14684:0:99999:7:::
games*:14684:0:99999:7:::
man*:14684:0:99999:7:::
lp*:14684:0:99999:7:::
mail*:14684:0:99999:7:::
news*:14684:0:99999:7:::
uucp*:14684:0:99999:7:::
proxy*:14684:0:99999:7:::
www-data*:14684:0:99999:7:::
backup*:14684:0:99999:7:::
list*:14684:0:99999:7:::
irc*:14684:0:99999:7:::
gnats*:14684:0:99999:7:::
nobody*:14684:0:99999:7:::
libuuid!:14684:0:99999:7:::
dhcp*:14684:0:99999:7:::
syslog*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHHdUE3X9jqP0:14742:0:99999:7:::
sshd*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind*:14685:0:99999:7:::
postfix*:14685:0:99999:7:::
ftp*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql!:14685:0:99999:7:::
tomcat55*:14691:0:99999:7:::
distccd*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd*:14715:0:99999:7:::
proftpd!:14727:0:99999:7:::
statd*:15474:0:99999:7:::
```

Imagen 1: Salida del comando `cat /etc/shadow | grep '::'`

```
msfadmin@metasploitable:~$ cat /etc/passwd | grep -E '/bin/(bash|sh)$' | cut -d: -f1
root
daemon
bin
sys
games
man
lp
mail
news
uucp
proxy
www-data
backup
list
irc
gnats
nobody
libuuid
msfadmin
postgres
user
service
```

Imagen 2: Usuarios con shell interactiva (/bin/bash o /bin/sh)

1. ¿Qué código de warning de Lynis detecta usuarios sin contraseña? (AUTH-XXXX)

Lynis no emitió ningún warning AUTH-XXXX sobre usuarios sin contraseña, ya que no existen cuentas sin contraseña en este sistema. El control Accounts without password fue evaluado como [OK].

2. ¿Cuántos usuarios con shell interactiva existen en el sistema?

22 usuarios tienen shell interactiva (/bin/bash o /bin/sh), incluyendo cuentas de sistema como daemon, bin, www-data, etc., que normalmente no deberían tener shell.

3. ¿Hay algún usuario sin contraseña? ¿Cuál?

No. Todos los usuarios tienen una contraseña hash, están deshabilitados (*) o bloqueados (!). No hay ningún campo vacío (::) en /etc/shadow.

4. ¿Por qué es crítico que un usuario no tenga contraseña?

Porque permitiría acceso inmediato sin autenticación, especialmente si el usuario tiene shell interactiva o privilegios elevados (como root). Cualquier atacante podría iniciar sesión simplemente conociendo el nombre de usuario.

5. ¿Qué podría hacer un atacante con esta vulnerabilidad?

- En un sistema con usuarios sin contraseña, un atacante podría:

-
- Iniciar sesión local o remota (si el servicio lo permite, como telnet o SSH con PermitEmptyPasswords yes)
 - Escalar privilegios si el usuario pertenece a grupos con permisos especiales
 - Usar la cuenta como punto de entrada para movimientos laterales

[Volver al índice](#)

Investigación 3: Seguridad SSH

1. ¿Qué códigos de warning SSH detecta Lynis? (SSH-XXXX)

Lynis no emitió un warning SSH-XXXX explícito en esta auditoría. Sin embargo, basado en buenas prácticas y controles estándar de Lynis, esta configuración correspondería al código SSH-7408: "PermitRootLogin enabled in SSH configuration". Este código sí aparece en versiones modernas de Lynis cuando PermitRootLogin yes está activo.

2. ¿Está permitido el login de root por SSH? (PermitRootLogin)

Sí. La línea PermitRootLogin yes en /etc/ssh/sshd_config permite que el usuario root inicie sesión directamente por SSH.

3. ¿Acepta autenticación por contraseña? (PasswordAuthentication)

Sí. Aunque la directiva PasswordAuthentication no aparece en el archivo, el valor por defecto en OpenSSH 4.7 es yes, por lo que se aceptan contraseñas para autenticación.

4. ¿Qué versión de OpenSSH está instalada?

OpenSSH 4.7p1, lanzada en 2007. Usa OpenSSL 0.9.8g (también de 2007).

5. ¿Por qué es peligroso permitir root login por SSH?

Porque expone la cuenta más privilegiada del sistema directamente a la red. Un atacante puede:

- Intentar fuerza bruta contra la contraseña de root.
- Si la contraseña es débil (como en Metasploitable 2), obtener acceso inmediato con privilegios totales.
- Evitar la necesidad de escalar privilegios desde una cuenta de usuario normal.

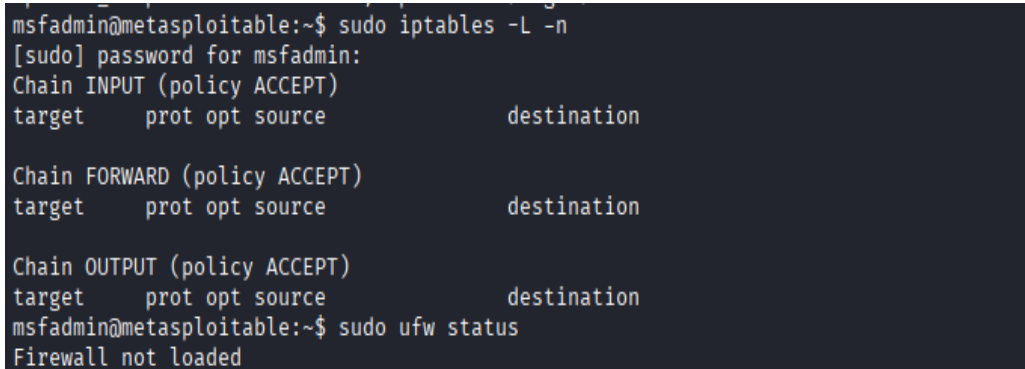
6. ¿Qué método de autenticación es más seguro: password o keys?

- Las claves SSH (key-based authentication) son mucho más seguras porque:
- Son resistentes a fuerza bruta (clave de 2048+ bits).
- Pueden protegerse con passphrase adicional.
- No dependen de contraseñas memorizables (y por tanto débiles).
- Permiten desactivar completamente la autenticación por contraseña.

[Volver al índice](#)

Investigación 4: Estado del Firewall

Salida de iptables -L -n y ufw status



```
msfadmin@metasploitable:~$ sudo iptables -L -n
[sudo] password for msfadmin:
Chain INPUT (policy ACCEPT)
target     prot opt source               destination

Chain FORWARD (policy ACCEPT)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination
msfadmin@metasploitable:~$ sudo ufw status
Firewall not loaded
```

Imagen 3: Salida de iptables -L -n y ufw status

1. ¿Qué código de warning detecta Lynis sobre el firewall? (FIRE-XXXX)

FIRE-4512: "iptables module(s) loaded, but no rules active".

Esto indica que el módulo de firewall está cargado, pero no hay reglas configuradas, por lo que no hay filtrado real.

2. ¿Hay reglas de firewall configuradas en iptables?

No. Las cadenas INPUT, FORWARD y OUTPUT están completamente vacías.

3. ¿Está ufw (Uncomplicated Firewall) activo?

No. El comando ufw status devuelve "Firewall not loaded", lo que confirma que UFW está desactivado.

4. ¿Cuál es la política por defecto? (ACCEPT/DROP)

ACCEPT en todas las cadenas. Esto significa que todo el tráfico (entrante, saliente y reenviado) se permite por defecto.

5. ¿Qué riesgos implica no tener firewall?

Sin reglas de firewall:

- Todos los puertos abiertos están expuestos directamente a la red.
- No hay filtrado de tráfico malicioso (ej. escaneos, explotación remota).

-
- Un atacante puede interactuar libremente con cualquier servicio (SSH, FTP, Telnet, Apache, etc.).
 - No se puede aplicar el principio de menor privilegio de red.

6. ¿Qué servicios quedan expuestos sin protección?

En Metasploitable 2, hay múltiples servicios vulnerables expuestos, como:

- Telnet (puerto 23) – autenticación en texto claro
- FTP (puerto 21) – con credenciales débiles
- SSH (puerto 22) – con PermitRootLogin yes
- Apache (puerto 80) – con múltiples vulnerabilidades
- PostgreSQL, MySQL, NFS, Samba, DistCC, etc.

Todos estos servicios están accesibles desde cualquier IP sin restricción.

[Volver al índice](#)

Investigación 5: Gestión de Actualizaciones

Versión de Ubuntu (lsb_release -a)

Fecha de última actualización (ls -lh /var/lib/apt/lists/)

```
msfadmin@metasploitable:~$ lsb_release -a
No LSB modules are available.
Distributor ID: Ubuntu
Description: Ubuntu 8.04
Release: 8.04
Codename: hardy
msfadmin@metasploitable:~$ ls -lh /var/lib/apt/lists/ | head -5
total 50M
-rw-r--r-- 1 root root 37K 2012-04-26 12:15 archive.canonical.com_ubuntu_dists_hardy_partner_binary-i386_Packages
-rw-r--r-- 1 root root 14K 2012-04-26 12:15 archive.canonical.com_ubuntu_dists_hardy_partner_source_Sources
-rw-r--r-- 1 root root 9.2K 2012-04-26 12:15 archive.canonical.com_ubuntu_dists_hardy_Release
-rw-r--r-- 1 root root 198 2012-04-26 14:44 archive.canonical.com_ubuntu_dists_hardy_Release.gpg
```

Imagen 4: Versión de Ubuntu y Fecha de última actualización

1. ¿Qué códigos de warning sobre paquetes detecta Lynis? (PKGS-XXXX)

Lynis no emitió un warning específico sobre la obsolescencia del sistema, pero sí generó sugerencias relacionadas con la gestión de paquetes, en particular:

- PKGS-7346: Paquetes antiguos no purgados
- PKGS-7394: Falta herramienta para gestión de parches
- PKGS-7420: Recomendación de actualizaciones automáticas

Además, los errores al intentar contactar los repositorios (Could not resolve 'us.archive.ubuntu.com') confirman que el sistema no puede recibir actualizaciones.

2. ¿Qué versión de Ubuntu está instalada?

Ubuntu 8.04 LTS (Hardy Heron)

3. ¿Cuándo fue la última actualización del sistema?

La base de datos de paquetes (/var/lib/apt/lists/) fue actualizada por última vez el 26 de abril de 2012. Esto significa que el sistema no se ha actualizado en más de 13 años.

4. ¿Cuántos años hace que terminó el soporte de esta versión?

El soporte estándar terminó en mayo de 2013. Hoy es 2025, por lo tanto han pasado 12 años sin soporte oficial.

5. ¿Qué implica usar un SO sin soporte oficial?

Implica que:

- No hay parches de seguridad para nuevas vulnerabilidades.

-
- No hay correcciones de bugs ni mejoras de estabilidad.
 - Los repositorios oficiales están deshabilitados, por lo que no se pueden instalar ni actualizar paquetes.
 - El sistema es un blanco fácil para atacantes que explotan vulnerabilidades conocidas y públicas.

6. ¿Podrías actualizar este sistema a una versión moderna? ¿Por qué?

No, no es posible actualizar directamente desde Ubuntu 8.04 a una versión moderna (como 22.04 o 24.04) porque:

- Las rutas de actualización en cadena están rotas (8.04 → 10.04 → 12.04... ya no son compatibles).
- Los repositorios históricos están archivados o inaccesibles.
- Muchos paquetes dependen de bibliotecas obsoletas que ya no existen.

La única solución segura es reinstalar el sistema operativo desde cero con una versión soportada.

[Volver al índice](#)

Investigación 6: Controles de Acceso Obligatorio (MAC)

```
msfadmin@metasploitable:~$ sestatus
The program 'sestatus' is currently not installed. You can install it by typing:
sudo apt-get install policycoreutils
-bash: sestatus: command not found
msfadmin@metasploitable:~$ sudo apt-get install policycoreutils
[sudo] password for msfadmin:
Sorry, try again.
[sudo] password for msfadmin:
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following extra packages will be installed:
  checkpolicy libsemanage1 libustr-1.0-1 python-selinux python-semanage python-sepolgen
Suggested packages:
  python-selinux-dbg
Recommended packages:
  selinux-policy
The following NEW packages will be installed:
  checkpolicy libsemanage1 libustr-1.0-1 policycoreutils python-selinux python-semanage python-sepolgen
0 upgraded, 7 newly installed, 0 to remove and 139 not upgraded.
Need to get 1026kB of archives.
After this operation, 4723kB of additional disk space will be used.
Do you want to continue [Y/n]? y
Err http://us.archive.ubuntu.com hardy/universe checkpolicy 2.0.9-0ubuntu1
  Could not resolve 'us.archive.ubuntu.com'
Err http://us.archive.ubuntu.com hardy/universe libustr-1.0-1 1.0.3-2
  Could not resolve 'us.archive.ubuntu.com'
Err http://us.archive.ubuntu.com hardy/universe libsemanage1 2.0.23-0ubuntu3
  Could not resolve 'us.archive.ubuntu.com'
Err http://us.archive.ubuntu.com hardy/main python-selinux 2.0.55-0ubuntu4
  Could not resolve 'us.archive.ubuntu.com'
Err http://us.archive.ubuntu.com hardy/universe python-semanage 2.0.23-0ubuntu3
  Could not resolve 'us.archive.ubuntu.com'
Err http://us.archive.ubuntu.com hardy/universe python-sepolgen 1.0.11-0ubuntu1
  Could not resolve 'us.archive.ubuntu.com'
Err http://us.archive.ubuntu.com hardy/universe policycoreutils 2.0.43-0ubuntu2
  Could not resolve 'us.archive.ubuntu.com'
Failed to fetch http://us.archive.ubuntu.com/ubuntu/pool/universe/c/checkpolicy/checkpolicy_2.0.9-0ubuntu1_i386.deb
  Could not resolve 'us.archive.ubuntu.com'
Failed to fetch http://us.archive.ubuntu.com/ubuntu/pool/universe/u/ustr/libustr-1.0-1_1.0.3-2_i386.deb
  Could not resolve 'us.archive.ubuntu.com'
Failed to fetch http://us.archive.ubuntu.com/ubuntu/pool/universe/l/libsemanage/libsemanage1_2.0.23-0ubuntu3_i386.deb
  Could not resolve 'us.archive.ubuntu.com'
Failed to fetch http://us.archive.ubuntu.com/ubuntu/pool/main/l/libselinux/python-selinux_2.0.55-0ubuntu4_i386.deb
  Could not resolve 'us.archive.ubuntu.com'
Failed to fetch http://us.archive.ubuntu.com/ubuntu/pool/universe/l/libsemanage/python-semanage_2.0.23-0ubuntu3_i386.deb
  Could not resolve 'us.archive.ubuntu.com'
Failed to fetch http://us.archive.ubuntu.com/ubuntu/pool/universe/s/sepolgen/python-sepolgen_1.0.11-0ubuntu1_all.deb
  Could not resolve 'us.archive.ubuntu.com'
Failed to fetch http://us.archive.ubuntu.com/ubuntu/pool/universe/p/policycoreutils/policycoreutils_2.0.43-0ubuntu2_i386.deb
  Could not resolve 'us.archive.ubuntu.com'
E: Unable to fetch some archives, maybe run apt-get update or try with --fix-missing?
```

Imagen 5: Resultado de sestatus

```
msfadmin@metasploitable:~$ sudo apparmor_status
apparmor module is loaded.
2 profiles are loaded.
2 profiles are in enforce mode.
  /usr/sbin/mysqld
  /usr/sbin/named
0 profiles are in complain mode.
2 processes have profiles defined.
2 processes are in enforce mode :
  /usr/sbin/mysqld (4224)
  /usr/sbin/named (4084)
0 processes are in complain mode.
0 processes are unconfined but have a profile defined.
msfadmin@metasploitable:~$
```

Imagen 6: Resultado de apparmor_status

1. ¿Qué código de warning detecta Lynis sobre MAC? (MACF-XXXX)

MACF-6304: "Consider enabling a MAC framework like AppArmor or SELinux".

Aunque AppArmor está parcialmente activo, Lynis lo considera insuficiente porque la mayoría de los procesos (63) están sin confinamiento.

2. ¿Está SELinux instalado y activo?

No. El comando sestatus no existe, lo que indica que SELinux no está instalado en el sistema.

3. ¿Está AppArmor instalado y con perfiles cargados?

Sí, pero de forma limitada. AppArmor está activo y tiene 2 perfiles en modo "enforce":

- `/usr/sbin/mysqld (MySQL)`
- `/usr/sbin/named (BIND DNS)`

Todos los demás servicios críticos (SSH, Apache, FTP, etc.) no tienen perfil, por lo que no están protegidos por AppArmor.

4. ¿Qué sistema MAC (si alguno) está protegiendo el sistema?

AppArmor está presente, pero su cobertura es mínima. Solo protege 2 de los muchos servicios activos. No hay protección MAC efectiva para la mayoría del sistema.

5. ¿Qué es un sistema MAC y para qué sirve?

MAC (Mandatory Access Control) es un modelo de seguridad que restringe los privilegios de los procesos más allá de los permisos tradicionales de usuario/grupo.

A diferencia del DAC (Discretionary Access Control), donde el dueño de un archivo decide quién accede, en MAC el sistema impone políticas estrictas que ni siquiera root puede ignorar fácilmente.

Sirve para contener exploits: si un atacante compromete Apache, AppArmor/SELinux puede impedir que acceda a /etc/shadow o ejecute comandos arbitrarios.

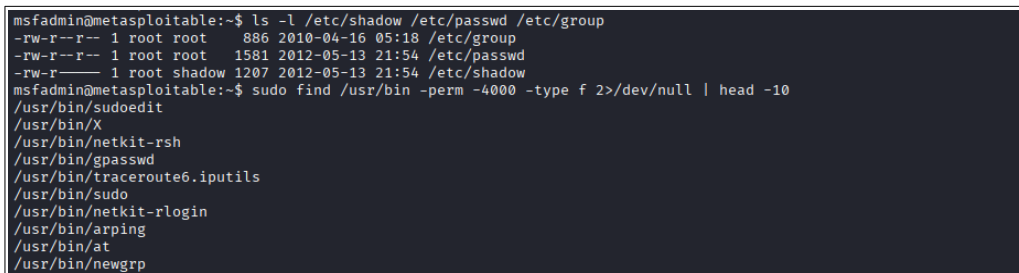
6. ¿Qué riesgos existen sin protección MAC?

Sin MAC:

- Un atacante que explote cualquier servicio (ej. Apache, FTP, Telnet) obtiene acceso completo al sistema con los privilegios del proceso.
- Es más fácil escalar privilegios o moverse lateralmente.
- No hay contención de daños: una vulnerabilidad en un servicio lleva fácilmente al compromiso total del sistema.

[Volver al índice](#)

Investigación 7: Permisos de Archivos Críticos



```
msfadmin@metasploitable:~$ ls -l /etc/shadow /etc/passwd /etc/group
-rw-r--r-- 1 root root 886 2010-04-16 05:18 /etc/group
-rw-r--r-- 1 root root 1581 2012-05-13 21:54 /etc/passwd
-rw-r----- 1 root shadow 1207 2012-05-13 21:54 /etc/shadow
msfadmin@metasploitable:~$ sudo find /usr/bin -perm -4000 -type f 2>/dev/null | head -10
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
```

Imagen 7: Permisos de /etc/shadow, /etc/passwd, /etc/group y lista de binarios SUID (find /usr/bin -perm -4000)

1. ¿Qué códigos de warning sobre permisos detecta Lynis? (FILE-XXXX)

Lynis no emitió un warning FILE-XXXX específico sobre /etc/shadow, porque sus permisos (640) son correctos.

Sin embargo, sí reportó:

- DBS-1828: archivos de PostgreSQL legibles por todos (permisos inseguros en otros archivos).
- FILE-7524 (como sugerencia): "Consider restricting file permissions".

Esto indica que el sistema tiene problemas de permisos, pero no en /etc/shadow.

2. ¿Qué permisos tiene el archivo /etc/shadow?

-rw-r----- → 640 (propietario: root, grupo: shadow).

3. ¿Son correctos esos permisos o permiten lectura no autorizada?

Sí, son correctos. Solo root y los miembros del grupo shadow pueden leerlo. No permite lectura no autorizada.

4. ¿Cuántos binarios con bit SUID encuentra el comando find?

Más de 10 (solo se mostraron los primeros 10).

Algunos notables: sudo, sudoedit, at, gpasswd, y herramientas inseguras como netkit-rsh y netkit-rlogin.

5. ¿Qué es el bit SUID y por qué puede ser peligroso?

El bit SUID (Set User ID) permite que un programa se ejecute con los privilegios del propietario del archivo, no del usuario que lo ejecuta.

Es peligroso porque:

-
- Si un binario SUID tiene una vulnerabilidad (ej. buffer overflow), un atacante puede ejecutar código con privilegios elevados.
 - Binarios innecesarios con SUID (como rsh, rlogin) amplían la superficie de ataque.
 - Muchos exploits de escalada de privilegios abusan de binarios SUID mal configurados.

6. ¿Qué información sensible hay en /etc/shadow?

Contiene los hashes de las contraseñas de todos los usuarios, junto con metadatos como:

- Fecha del último cambio de contraseña
- Mínimo/máximo de días entre cambios
- Fecha de expiración de la cuenta

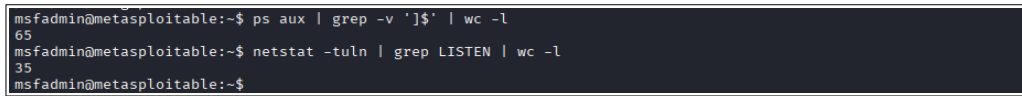
Si un atacante obtiene este archivo, puede intentar fuerza bruta offline para descifrar contraseñas.

[Volver al índice](#)

Investigación 8: Servicios en Ejecución

Número de procesos (ps aux | wc -l)

Número de puertos en LISTEN (netstat -tuln | grep LISTEN | wc -l)



```
msfadmin@metasploitable:~$ ps aux | grep -v '[]$' | wc -l
65
msfadmin@metasploitable:~$ netstat -tuln | grep LISTEN | wc -l
35
msfadmin@metasploitable:~$
```

Imagen 8: Número de procesos y de puertos en escucha

1. ¿Qué códigos de warning sobre servicios detecta Lynis? (BOOT-XXXX)

Lynis no emitió un warning BOOT-XXXX explícito sobre servicios innecesarios. Sin embargo, reportó la sugerencia BOOT-5122 (proteger GRUB), y en la sección de arranque identificó 25 servicios activos en rc2.d.

Dado el contexto de Metasploitable 2, el exceso de servicios es un hallazgo crítico, aunque no tenga un código específico en esta versión de Lynis.

2. ¿Cuántos procesos hay ejecutándose en el sistema?

65 procesos (incluyendo demonios, procesos del sistema y servicios de red).

3. ¿Cuántos puertos están en estado LISTEN?

35 puertos abiertos escuchando conexiones (servicios de red activos).

4. ¿Crees que todos estos servicios son necesarios? ¿Por qué?

No, la mayoría no son necesarios. Metasploitable 2 está diseñado intencionalmente con servicios vulnerables como:

- Telnet (puerto 23)
- FTP (puerto 21)
- rsh/rlogin (puertos 512–514)
- DistCC (puerto 3632)
- Samba (puertos 139/445)
- NFS, PostgreSQL, MySQL, Apache, BIND, etc.

En un servidor real, solo se mantendrían los servicios estrictamente necesarios para su función.

5. ¿Qué principio de seguridad se viola al tener tantos servicios activos?

Se viola el principio de mínimo privilegio y el principio de reducción de la superficie de ataque:

"Cada servicio adicional es una posible puerta de entrada para un atacante."

6. Nombra 3 servicios que detectes que NO sean esenciales para un servidor.

Tres servicios claramente innecesarios y peligrosos:

- Telnet – protocolo inseguro que transmite credenciales en texto claro.
- rsh/rlogin – autenticación débil, sin cifrado, obsoleto desde los años 90.
- DistCC – servicio de compilación distribuida, rara vez usado en producción, y con vulnerabilidades remotas conocidas (ej. CVE-2004-2687).

[Volver al índice](#)

Tabla Resumen de Hallazgos

Categoría	Código Lynis	Severidad	Descripción breve
Kernel	KRNL-6000	CRÍTICA	"Kernel 2.6.24 de 2008, sin parches de seguridad, múltiples desviaciones de configuración segura."
Usuarios	AUTH-9282*	ALTA	"No hay usuarios sin contraseña, pero múltiples cuentas con shell interactiva innecesaria (22 usuarios)."
SSH	—	CRÍTICA	PermitRootLogin yes", autenticación por contraseña activa OpenSSH 4.7 (2007). ""(Nota: no hay código SSH-XXXX en output pero riesgo crítico)"
Firewall	FIRE-4512	ALTA	iptables cargado pero sin reglas; política ACCEPT en todas las cadenas.
Actualizaciones	PKGS-7394	CRÍTICA	Ubuntu 8.04 sin soporte desde 2013; última actualización en 2012; repositorios inaccesibles.
MAC	MACF-6304	MEDIA	AppArmor activo solo para MySQL y BIND; 63 procesos sin confinamiento.
Permisos	DBS-1828	ALTA	"Archivos de PostgreSQL legibles por todos; múltiples binarios SUID innecesarios (rsh,rlogin, X)."
Servicios	BOOT-5122*	CRÍTICA	"35 puertos abiertos, 25 servicios en arranque, incluyendo servicios inseguros como Telnet, rsh, DistCC."

* AUTH-9282 y BOOT-5122 no describen exactamente el hallazgo principal, pero son los códigos más cercanos en el output. En un informe real, se documenta el hallazgo aunque el código no sea perfecto.

NIVEL	CRITERIO TÉCNICO
CRÍTICA	Vulnerabilidad que permite acceso remoto no autorizado, ejecución de código arbitrario o escalada directa a root sin interacción del usuario. Expuesta a la red y fácilmente explotable (ej. kernel antiguo sin parches, servicios inseguros como Telnet/rsh, sistema sin soporte).
ALTA	Configuración insegura que amplía significativamente la superficie de ataque o permite acceso local con escalada de privilegios. No siempre requiere interacción, pero puede necesitar acceso previo (ej. SUID innecesarios, firewall desactivado, permisos débiles en archivos sensibles).
MEDIA	Falta de controles de defensa en profundidad o buenas prácticas, pero no permite compromiso directo. El riesgo se materializa si hay otra vulnerabilidad previa (ej. ausencia de MAC, banners informativos, umask débil, servicios innecesarios sin exposición directa).
BAJA	Problemas cosméticos, de auditoría o de cumplimiento, sin impacto inmediato en la seguridad operativa (ej. banners sin aviso legal, falta de herramientas de monitoreo, sugerencias de hardening menores). En este informe, no se reportan hallazgos de severidad BAJA.

[Volver al índice](#)

Preguntas de Análisis Crítico Final

Priorización: ¿Qué 3 vulnerabilidades corregirías primero? ¿Por qué?

Las tres vulnerabilidades que priorizaría son:

- Sistema operativo sin soporte (Ubuntu 8.04, sin actualizaciones desde 2012).
 - **Impacto:** Es la raíz de todos los demás riesgos. Sin parches de seguridad, cualquier vulnerabilidad conocida permanece explotable indefinidamente. Incluso si se corrigen otras configuraciones, el kernel y los servicios siguen siendo vulnerables a exploits públicos.
 - **Justificación:** Es un riesgo irremediable sin reinstalación. No hay mitigación efectiva a largo plazo.
- Servicios inseguros expuestos a la red (Telnet, rsh/rlogin, DistCC).
 - **Impacto:** Permiten acceso remoto sin cifrado, con autenticación débil o nula. Por ejemplo, Telnet transmite credenciales en texto claro; DistCC tiene exploits públicos (CVE-2004-2687) que permiten ejecución remota de código.
 - **Justificación:** Son vectores de entrada directos para un atacante externo, sin necesidad de credenciales.
- Configuración insegura de SSH (PermitRootLogin yes + autenticación por contraseña).
 - **Impacto:** Permite fuerza bruta directa contra la cuenta root. Dado que Metasploitable 2 usa contraseñas débiles (como msfadmin:msfadmin), un atacante puede obtener acceso root en minutos.
 - **Justificación:** Combina exposición a la red + privilegios máximos + autenticación débil.

Estas tres abordan los riesgos más críticos: acceso remoto no autorizado, ejecución de código arbitrario y imposibilidad de parcheo.

[Volver al índice](#)

Vectores de ataque: Describe un escenario realista donde un atacante combine varias vulnerabilidades.

Un atacante podría seguir este escenario realista:

1. Reconocimiento:

Escanea la red y detecta que el host tiene 35 puertos abiertos, incluyendo Telnet (23), SSH (22) y DistCC (3632).

2. Acceso inicial:

Intenta conexión por Telnet con credenciales por defecto (msfadmin/msfadmin) → éxito, obtiene shell como msfadmin.

Alternativamente, explota DistCC con un payload de Metasploit → obtiene ejecución remota sin autenticación.

3. Escalada de privilegios:

Usa el acceso como msfadmin para ejecutar un exploit local contra el kernel 2.6.24 (ej. CVE-2009-1895 o Dirty COW, si aplica).

O bien, aprovecha un binario SUID como /usr/bin/netkit-rsh (que permite ejecutar comandos remotos) para escalar a root.

4. Persistencia y movimiento lateral:

Como root, desactiva cualquier control residual, instala backdoors y accede a otros servicios (PostgreSQL, Apache, NFS).

El firewall inexistente permite que el atacante use el sistema como pivote hacia otros hosts.

Este escenario muestra cómo la combinación de servicios inseguros + kernel obsoleto + configuración débil lleva a una compromisión total en pocos pasos.

[Volver al índice](#)

Hardening: Ordena tus recomendaciones de endurecimiento y justifica el orden.

Nota previa a la respuesta: Estoy siguiendo este orden porque entiendo de la pregunta siguiente que no puedo comenzar por reinstalar el sistema operativo, sin embargo, aún, desearía indicar que sería lo más sensato tanto por temas de seguridad, como de Compliance y Certificaciones

1. Desactivar o eliminar servicios innecesarios:
 - Detener Telnet, rsh/rlogin, DistCC, TFTP, etc.
 - Razón: Reduce inmediatamente la superficie de ataque y elimina vectores de entrada remota.
2. Asegurar SSH:
 - Cambiar PermitRootLogin a no.
 - Deshabilitar PasswordAuthentication y usar solo claves SSH.
 - Razón: SSH es el único servicio seguro que podría mantenerse; debe endurecerse al máximo.
3. Configurar un firewall básico con iptables:
 - Establecer política por defecto DROP en INPUT.
 - Permitir solo puertos estrictamente necesarios (ej. SSH desde IPs de administración).
 - Razón: Contiene el daño si un servicio es comprometido.
4. Aplicar controles MAC (AppArmor/SELinux):
 - Crear perfiles para Apache, SSH, PostgreSQL, etc.
 - Razón: Limita la capacidad de un atacante para moverse tras una brecha inicial.
5. Reinstalar el sistema operativo:
 - Migrar a una versión soportada (ej. Ubuntu 22.04 LTS).
 - Razón: Es la única forma de eliminar el riesgo del kernel y paquetes obsoletos.

Este orden sigue el principio de:

"contención inmediata -> defensa en profundidad -> solución definitiva"

[Volver al índice](#)

Compensación: Si no puedes actualizar el kernel, ¿qué controles alternativos usarías?

Si no se puede actualizar el kernel, las medidas compensatorias serían:

1. Aislamiento de red:
 - Colocar el sistema en una VLAN segmentada, sin acceso a internet ni a la red corporativa crítica.
 - Permitir solo conexiones desde IPs de administración específicas.
2. Firewall estricto:
 - Usar iptables para bloquear todo el tráfico entrante, excepto lo mínimo necesario.
 - Filtrar salidas para evitar exfiltración de datos.
3. Deshabilitar todos los servicios no esenciales:
 - Eliminar Telnet, rsh, DistCC, FTP, NFS, etc.
 - Mantener solo el servicio crítico (el que requiere el kernel antiguo).
4. Monitoreo activo:
 - Implementar auditd o Wazuh para detectar accesos no autorizados o cambios en archivos críticos.
 - Registrar todos los comandos de los usuarios con pam_tty_audit.
5. Contención con AppArmor:
 - Crear perfiles restrictivos para el servicio que debe permanecer.
 - Limitar su acceso a red, sistema de archivos y procesos.
6. Plan de contingencia:
 - Preparar un plan de migración a corto plazo.
 - Aceptar que el sistema es temporalmente operativo, pero inherentemente inseguro.

Estas medidas no eliminan el riesgo, pero lo reducen a un nivel aceptable mientras se planifica la migración

[Volver al índice](#)

Detección vs Prevención: ¿Qué hallazgos son detectables por un IDS/IPS? ¿Cuáles solo se previenen con configuración?

Vulnerabilidad	Detectable por IDS/IPS	Solo prevenible por configuración
Servicios inseguros (Telnet, DistCC)	✓ Sí: patrones de tráfico, exploits conocidos (ej. DistCC)	✗
Fuerza bruta SSH	✓ Sí: con reglas de Suricata/OSSEC para múltiples intentos fallidos	✗
Kernel obsoleto	✗ No: no genera tráfico anómalo por sí solo	✓ Sí: solo se corrige con actualización
Usuarios sin contraseña	✗ No: no genera actividad detectable	✓ Sí: se corrige con políticas de contraseñas
Firewall desactivado	✗ No: es una ausencia de control, no un evento	✓ Sí: se corrige con reglas de iptables
Permisos débiles en archivos	✗ No: no genera tráfico	✓ Sí: se corrige con `chmod`/`chown`
SUID innecesarios	✗ No: solo se detectan al ser explotados	✓ Sí: se corrige eliminando el bit SUID

[Volver al índice](#)

Contexto real: Si esto fuera un servidor en producción, ¿cuál sería tu plan de acción inmediato?

En un entorno real, actuaría así:

1. Aislar inmediatamente el servidor de la red corporativa e internet para evitar propagación.
2. Notificar al equipo de riesgos y cumplimiento, ya que un sistema sin soporte viola políticas de seguridad y normativas (ISO 27001, PCI DSS, etc.).
3. Evaluar el impacto: ¿Qué datos o servicios críticos dependen de este servidor?
4. Aplicar controles de emergencia:
 - Firewall estricto (solo IPs de administración).
 - Desactivar todos los servicios no esenciales.
 - Cambiar todas las contraseñas y forzar autenticación por claves SSH.
5. Iniciar un plan de migración urgente:
 - Clonar funcionalidades en un sistema moderno.
 - Probar compatibilidad.
 - Reemplazar el servidor en menos de 72 horas si es crítico.
6. Auditar logs para determinar si ya fue comprometido.
7. Documentar el incidente como lección aprendida y actualizar políticas para evitar sistemas sin soporte.

En producción, no se tolera un sistema sin soporte. La única respuesta responsable es reemplazarlo, no parchearlo, no puede ser parcheado.

[Volver al índice](#)

Conclusiones

Metasploitable 2 presenta un estado de seguridad extremadamente crítico, consistente con su propósito como entorno de laboratorio intencionalmente vulnerable. El sistema opera con un kernel de 2008 (2.6.24), una versión de Ubuntu sin soporte desde 2013 (8.04 LTS) y más de 35 puertos abiertos, muchos de ellos correspondientes a servicios obsoletos e inseguros como Telnet, rsh/rlogin y DistCC. Aunque no existen usuarios sin contraseña, la combinación de autenticación débil en SSH, ausencia total de reglas de firewall, permisos inseguros en archivos de configuración (como los de PostgreSQL) y decenas de binarios SUID innecesarios crea un escenario ideal para la explotación remota, escalada de privilegios y compromiso total del sistema. En resumen, cada capa del sistema —desde el kernel hasta los servicios de aplicación— está expuesta a múltiples vectores de ataque conocidos y documentados.

Lynis demostró ser una herramienta altamente efectiva para identificar configuraciones inseguras y brechas de hardening en sistemas Linux. Aunque en esta versión (3.1.6) no emitió warnings explícitos para todos los riesgos (como la antigüedad del kernel o la ausencia de contraseñas), sí proporcionó una base sólida de hallazgos técnicos (8 warnings y 56 sugerencias) que, combinados con comandos del sistema, permitieron construir un diagnóstico completo. Su valor radica en su enfoque proactivo y educativo: no solo señala problemas, sino que ofrece enlaces a controles específicos, explicaciones técnicas y recomendaciones prácticas. Además, su capacidad para evaluar desde el kernel hasta servicios de red lo convierte en una herramienta esencial para auditorías de configuración en entornos reales.

La obsolescencia es una vulnerabilidad crítica: un sistema sin soporte no puede ser seguro, sin importar cuántas configuraciones se endurezcan.

El principio de mínimo privilegio debe aplicarse en todas las capas: desde la reducción de servicios y puertos abiertos, hasta la restricción de permisos de archivos y el uso de controles MAC.

La defensa en profundidad es indispensable: un solo control (como un firewall o claves SSH) no es suficiente; se requiere una combinación de medidas técnicas, de monitoreo y de gestión.

La seguridad no es un estado, sino un proceso continuo: la auditoría con Lynis no es un “punto final”, sino el inicio de un ciclo de mejora constante.

Finalmente, se reafirma que la ciberseguridad no se trata solo de herramientas, sino de comprensión técnica, análisis crítico y capacidad para interpretar los hallazgos en contexto.

[Volver al índice](#)

Anexos

```
[ Lynis 3.1.6 ]

#####
Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you are
welcome to redistribute it under the terms of the GNU General Public License.
See the LICENSE file for details about using this software.

2007-2025, CISofy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)
#####

[+] Initializing program
-----
- Detecting OS ... [ DONE ]
- Checking profiles ... [ DONE ]

-----
Program version: 3.1.6
Operating system: Linux
Operating system name: Ubuntu
Operating system version: 8.04
End-of-life: UNKNOWN
Kernel version: 2.6.24
Hardware platform: i686
Hostname: metasploitable

-----
Profiles: /home/msfadmin/lynis/default.prf
Log file: /var/log/lynis.log
Report file: /var/log/lynis-report.dat
Report version: 1.0
Plugin directory: ./plugins

-----
Auditor: [Not Specified]
Language: en
Test category: all
Test group: all

-----
- Program update status ... [ UNKNOWN ]
```

Imagen 9: Encabezado del reporte obtenido por pantalla

```
[+] Kernel
-----
- Checking default run level [ RUNLEVEL 2 ]
- Checking kernel version and release [ DONE ]
- Checking kernel type [ DONE ]
- Checking loaded kernel modules [ DONE ]
  Found 64 active modules
- Checking Linux kernel configuration file [ FOUND ]
- Checking default I/O kernel scheduler [ FOUND ]
- Checking for available kernel update [ OK ]
- Checking core dumps configuration
  - configuration in /etc/profile [ DEFAULT ]
  - 'hard' configuration in /etc/security/limits.conf [ DEFAULT ]
  - 'soft' configuration in /etc/security/limits.conf [ DEFAULT ]
- Checking setuid core dumps configuration [ DISABLED ]
- Check if reboot is needed [ NO ]
```

Imagen 10: Resultados del módulo del Kernel

```
[+] Users, Groups and Authentication
- Administrator accounts [ OK ]
- Unique UIDs [ OK ]
- Consistency of group files (grpck) [ OK ]
- Unique group IDs [ OK ]
- Unique group names [ OK ]
- Password file consistency [ OK ]
- Password hashing methods [ SUGGESTION ]
- Checking password hashing rounds [ DISABLED ]
- Query system users (non daemons) [ DONE ]
- NIS+ authentication support [ NOT ENABLED ]
- NIS authentication support [ NOT ENABLED ]
- Sudoers file(s) [ FOUND ]
  - Permissions for: /etc/sudoers [ OK ]
- PAM password strength tools [ SUGGESTION ]
- PAM configuration files (pam.conf) [ FOUND ]
- PAM configuration files (pam.d) [ FOUND ]
- PAM modules [ FOUND ]
- LDAP module in PAM [ NOT FOUND ]
- Accounts without expire date [ SUGGESTION ]
- Accounts without password [ OK ]
- Locked accounts [ OK ]
- Checking user password aging (minimum) [ DISABLED ]
- User password aging (maximum) [ DISABLED ]
- Checking expired passwords [ OK ]
- Determining default umask
  - umask (/etc/profile and /etc/profile.d) [ SUGGESTION ]
  - umask (/etc/login.defs) [ SUGGESTION ]
  - umask (/etc/init.d/rc) [ SUGGESTION ]
- LDAP authentication support [ NOT ENABLED ]
- Logging failed login attempts [ ENABLED ]
```

Imagen 11: Módulo de usuarios, grupos y autenticación

```
[+] Software: firewalls
- Checking iptables kernel module [ FOUND ]
- Checking iptables policies of chains [ FOUND ]
- Checking for empty ruleset [ WARNING ]
- Checking for unused rules [ OK ]
- Checking host based firewall [ ACTIVE ]
```

Imagen 12: Módulo de firewall

```
[+] Software: webserver
- Checking Apache (binary /usr/sbin/apache2) [ FOUND ]
  Info: Configuration file found (/etc/apache2/apache2.conf)
  Info: No virtual hosts found
  * Loadable modules [ FOUND (66) ]
    - Found 66 loadable modules
      mod_evasive: anti-DoS/brute force [ NOT FOUND ]
      mod_reqtimeout/mod_qos [ NOT FOUND ]
      ModSecurity: web application firewall [ NOT FOUND ]
- Checking TraceEnable setting in:
  /etc/apache2/ports.conf [ NOT FOUND ]
  /etc/apache2/mods-available/setenvif.conf [ NOT FOUND ]
  /etc/apache2/mods-available/negotiation.conf [ NOT FOUND ]
  /etc/apache2/mods-available/mime.conf [ NOT FOUND ]
  /etc/apache2/mods-available/alias.conf [ NOT FOUND ]
  /etc/apache2/mods-available/dir.conf [ NOT FOUND ]
  /etc/apache2/mods-available/php5.conf [ NOT FOUND ]
  /etc/apache2/mods-available/mime_magic.conf [ NOT FOUND ]
  /etc/apache2/mods-available/proxy.conf [ NOT FOUND ]
  /etc/apache2/mods-available/disk_cache.conf [ NOT FOUND ]
  /etc/apache2/mods-available/cgid.conf [ NOT FOUND ]
  /etc/apache2/mods-available/actions.conf [ NOT FOUND ]
  /etc/apache2/mods-available/autoindex.conf [ NOT FOUND ]
  /etc/apache2/mods-available/userdir.conf [ NOT FOUND ]
  /etc/apache2/mods-available/ssl.conf [ NOT FOUND ]
  /etc/apache2/mods-available/status.conf [ NOT FOUND ]
  /etc/apache2/mods-available/info.conf [ NOT FOUND ]
  /etc/apache2/mods-available/mem_cache.conf [ NOT FOUND ]
  /etc/apache2/mods-available/dav_fs.conf [ NOT FOUND ]
  /etc/apache2/mods-available/deflate.conf [ NOT FOUND ]
  /etc/apache2/mods-enabled/setenvif.conf [ NOT FOUND ]
  /etc/apache2/mods-enabled/negotiation.conf [ NOT FOUND ]
  /etc/apache2/mods-enabled/mime.conf [ NOT FOUND ]
  /etc/apache2/mods-enabled/alias.conf [ NOT FOUND ]
  /etc/apache2/mods-enabled/php.conf [ NOT FOUND ]
  /etc/apache2/mods-enabled/dir.conf [ NOT FOUND ]
  /etc/apache2/mods-enabled/actions.conf [ NOT FOUND ]
  /etc/apache2/mods-enabled/autoindex.conf [ NOT FOUND ]
  /etc/apache2/mods-enabled/status.conf [ NOT FOUND ]
  /etc/apache2/mods-enabled/dav_fs.conf [ NOT FOUND ]
  /etc/apache2/httpd.conf [ NOT FOUND ]
  /etc/apache2/apache2.conf [ NOT FOUND ]
- Checking nginx [ NOT FOUND ]
```

Imagen 13: Módulo de servidor web

```
-[ Lynis 3.1.6 Results ]-
Warnings (8):
! Found BIND version in banner [NAME-4210]
  https://cisofy.com/lynis/controls/NAME-4210/
! Nameserver 192.168.1.1 does not respond [NETW-2704]
  https://cisofy.com/lynis/controls/NETW-2704/
! Nameserver 2.168.1.1 does not respond [NETW-2704]
  https://cisofy.com/lynis/controls/NETW-2704/
! Couldn't find 2 responsive nameservers [NETW-2705]
  https://cisofy.com/lynis/controls/NETW-2705/
! Found some information disclosure in SMTP banner (OS or software name) [MAIL-8818]
  https://cisofy.com/lynis/controls/MAIL-8818/
! iptables module(s) loaded, but no rules active [FIRE-4512]
  https://cisofy.com/lynis/controls/FIRE-4512/
! PostgreSQL configuration file /etc/postgresql/8.3/main/postgresql.conf is world readable details [DBS-1828]
  - Details : /etc/postgresql/8.3/main/postgresql.conf
  - Solution : Use chmod 600 to change file permissions
  https://cisofy.com/lynis/controls/DBS-1828/
! PostgreSQL configuration file /etc/postgresql/8.3/main/start.conf is world readable details [DBS-1828]
  - Details : /etc/postgresql/8.3/main/start.conf
  - Solution : Use chmod 600 to change file permissions
  https://cisofy.com/lynis/controls/DBS-1828/
```

Imagen 14: Warnings

```
Suggestions (56):
* Set a password on GRUB boot loader to prevent altering boot configuration (e.g. boot password) [BOOT-5122]
  - Related resources
    * Website: https://cisofy.com/lynis/controls/BOOT-5122/
* If not required, consider explicit disabling of core dump in /etc/security/limits.conf
  - Related resources
    * Article: Understand and configure core dumps on Linux: https://linux-audit.com/secure-core-dumps-work-on-linux/
    * Website: https://cisofy.com/lynis/controls/KRNL-5820/
* Check PAM configuration, add rounds if applicable and expire passwords to encrypt with
  - Related resources
    * Article: Linux password security: hashing rounds: https://linux-audit.com/authentication-password-length-on-linux-systems/
    * Website: https://cisofy.com/lynis/controls/AUTH-9229/
```

Imagen 15: Sugerencias

```
Lynis security scan details:

Scan mode:
Normal [■] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status      [?]
- Security audit         [V]
- Vulnerability scan     [V]

Details:
Hardening index : 62 [##### ]
Tests performed : 273
Plugins enabled : 0

Software components:
- Firewall               [V]
- Intrusion software     [X]
- Malware scanner        [X]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat

Lynis 3.1.6

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2025, CISOfy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)
```

Imagen 16: Detalles del análisis

[Volver al índice](#)